

Hunting for vulnerabilities: call for European protection of security researchers

Michal Rampášek¹, Jozef Andraško^{1,2}, Pavol Sokol³, Ondrej Hamulak^{1,2,4,*}

¹Institute of Information Technology Law and Intellectual Property Law, Comenius University Bratislava, Faculty of Law, Šafárikovo nám. 6, 81000 Bratislava, Slovak Republic

²Czech Law and Advanced Technologies Research Institute, Palacký University Olomouc, Faculty of Law, 17. listopadu 8, Olomouc 77111, Czech Republic

³Institute of Computer Science, Pavol Jozef Šafárik University, Faculty of Science, Jesenná 504001, Košice, Slovak Republic

⁴Department of Law, School of Business and Governance, Tallinn University of Technology, Akadeemia tee 3, Tallinn, Estonia

*Corresponding author: Czech Law and Advanced Technologies Research Institute, Palacký University Olomouc, Faculty of Law, 17. listopadu 8, Olomouc 77111, Czech Republic. E-mail: ondrej.hamulak@upol.cz

Abstract

The paper explores the role and legal protection of vulnerability reporters, namely cybersecurity researchers within the evolving EU cybersecurity framework. It examines who these researchers are, the value of their work, and the growing legal risks they face across Europe, as demonstrated by high-profile cases in the Netherlands, Malta, and Germany. Drawing on international human rights frameworks including EU Charter of Fundamental Rights, the paper argues that security research should be protected under the right to science and the freedom to conduct research. The paper advocates for defining ‘good-faith security research’ as a legally recognized safe harbour in EU law. A comparative analysis of selected international and EU legal frameworks, such as the UN Convention Against Cybercrime, Budapest Convention, EU Directive on attacks against information systems, the Cybersecurity Act, the NIS2 Directive, the Cyber Resilience Act, and national policies of a selected group of EU Member States, including the Netherlands, Belgium, France, Germany, Italy, Spain, Poland, Czechia, Slovakia, Malta along with the UK and the USA, reveals fragmented and insufficient protection. To address this, the paper calls for a coherent EU-wide framework based on two interlinked pillars: (i) mandatory coordinated vulnerability disclosure (CVD) procedures, and (ii) substantive legal exemptions for ethical security research. While the recent NIS2 Commission Implementing Regulation (EU) 2024/2690 for entities from digital infrastructure is a step forward, it lacks explicit protection for researchers. Therefore, the paper concludes with a call for integrating legal and technical safe harbours into EU cybersecurity legislation to ensure that vulnerability disclosure policies are not only adopted by entities but are also legally accessible and safe for the researchers, who rely on them.

Keywords security research, vulnerability, cyber security, coordinated vulnerability disclosure, criminal law, civil law

Introduction

Security researchers use their skills and knowledge to improve the cyber security resilience of products, services, and information systems. They play a crucial role in strengthening cybersecurity resilience by identifying and reporting vulnerabilities in products, services, and information systems. However, the act of vulnerability reporting carries the inherent risk of legal repercussions, including criminal prosecution. Various legal instruments, such as international information security standards, the Regulation (EU) 2019/881 of the European Parliament and of the Council of 17 April 2019 on the European Union Agency for Cybersecurity (ENISA) and on information and communications technology cybersecurity certification and repealing Regulation (EU) No 526/2013 (Cybersecurity Act, CSA), Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the Union, amending Regulation (EU) No 910/2014 and Directive (EU)

2018/1972, and repealing Directive (EU) 2016/1148 (NIS 2), Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act, CRA), require both public and private sector entities to establish processes for receiving vulnerability reports and coordinating disclosure mechanisms with security researchers.

This research focus on the evolving legal landscape in Europe concerning the protection of security researchers. By conducting a comparative analysis of legal frameworks in selected countries applying bottom-up or top-down approach, we aim to identify best practices and established legislative safeguards that can serve as models for further legal improvements. These jurisdictions were chosen for their diverse approaches to vulnerability disclosure and the protection of researchers, offering a wider perspective on how legal frameworks can adapt to balance security needs with legal certainty for researchers.

Received: 27 March 2025. Revised: 17 November 2025. Accepted: 12 December 2025

© The Author(s) 2026. Published by Oxford University Press. This is an Open Access article distributed under the terms of the Creative Commons Attribution License (<https://creativecommons.org/licenses/by/4.0/>), which permits unrestricted reuse, distribution, and reproduction in any medium, provided the original work is properly cited.

The principal research question in this paper is whether the current EU legal framework provides sufficient protection for security researchers engaged in ethical vulnerability discovery and disclosure. More specifically, we examine the extent to which legal provisions shield security researchers from criminal liability when engaging in good-faith security testing and reporting vulnerabilities.

Our research further investigates the legal risks security researchers face, differing national approaches to establishing safe harbours for researchers, the procedural and timing aspects of obtaining approval for vulnerability disclosure, the obligations of affected entities upon receiving vulnerability reports, and the applicability of coordinated vulnerability disclosure (CVD) frameworks in the selected European jurisdictions.

Our approach involves identifying relevant legal frameworks governing CVD processes and intersections between criminal, copyright, and cybersecurity regulations. Legal instruments are selected based on relevance and impact on security researchers. The primary research method is analytical, enabling identification of provisions and comparisons across jurisdictions. Framework analysis supports this and develops a conceptual understanding. Our evaluations of safe harbours and respective CVD processes use deductive reasoning based on empirical findings.

Our findings will highlight the strengths and weaknesses of current legislative approaches and propose recommendations for improving legal certainty for security researchers. By mapping out the evolving legal standards and regulatory measures, we seek to provide a foundation for policymakers and stakeholders to develop more robust legal protections, ensuring that ethical hacking remains a valuable tool in enhancing cybersecurity resilience without exposing researchers to undue legal risks.

The included research can be broadly grouped according to (i) security research and right to research, and (ii) safe harbours for security researcher and legal framework. Alexopoulos *et al.* [1] conducted a large-scale empirical study on vulnerability reporters in FLOSS projects, highlighting the diverse backgrounds, motivations, and contribution patterns of security researchers. Van Daalen [2] offers a strong perspective when he defends the ‘right to science’, suggesting that overly broad legal constraints hinder beneficial research, especially when such research is not demonstrably harmful. Xiaozhou *et al.* [3] conducted a systematic mapping study to analyse the structure, usage, and reliability of vulnerability databases in security research. Walshe and Simpson [4] discuss the operational side of reward programs for finding vulnerabilities and disclosing vulnerabilities, noting that organizations often fail to incorporate the findings into their broader security activities and are overwhelmed by low-value submissions. Finally, Zrahia [5] examines bug bounty programs from a public-policy perspective and suggests that governments can enhance cybersecurity by promoting well-managed platforms that reduce friction between organizations and ethical hackers. Arora *et al.* [6] illustrate that immediate disclosure can trigger a spike in malicious attacks, but it also speeds up the release of patches. Sen *et al.* [7], meanwhile, find that producers who have a reputation for rapid response cause reporters to delay (i.e. coordinate) disclosure more, which ultimately reduces overall risk. Lisi *et al.* [8] advocate an automated approach to responsible disclosure, using blockchain-based solutions to enforce deadlines and ensure that no party abuses disclosure timelines.

Second group covers legal and regulatory science articles. Pil’s [9] study compares vulnerability disclosure policies in the USA, EU,

and the Netherlands, highlighting the need to protect security researchers from legal liability, expand vulnerability disclosure programme adoption across sectors, and ensure transparency in vulnerability management. Dickmann [10] highlights how EU regulation, including the Directive 2014/53/EU of the European Parliament and of the Council of 16 April 2014 on the harmonisation of the laws of the Member States relating to the making available on the market of radio equipment and repealing Directive 1999/5/EC, imposes liability on manufacturers, who neglect vulnerabilities, ultimately suggesting that consistent vulnerability management can improve Internet of Things (IoT) security. Ruohonen and Timmers [11] pay particular attention to the CRA, highlighting that new obligations regarding actively exploited vulnerabilities are likely to change coordination practices and potentially intertwine with government powers. Sardaryzadeh’s [12] discussion of the Digital Millennium Copyright Act of 1998 (DMCA) in the USA reveals the tension between legitimate vulnerability research and the DMCA’s anticircumvention provisions, showing that the law’s narrow exceptions can push researchers to hesitate or take risks. Brodowski [13] focuses on how security researchers can navigate German and European criminal law to avoid liability while reporting software vulnerabilities. Vostoupal *et al.* [14] focuses on the legal aspects of responsible vulnerability disclosure and the legal risks associated with its implementation in the Czech Republic from civil law, administrative law and criminal law perspectives.

The paper proceeds as follows. The second part of the paper discusses vulnerability reporters and researchers. The third part introduces vulnerability research as part of security research. The fourth part analyses safe harbours in EU member states. The fifth part analyses safe harbours in EU cybersecurity law. Finally, the paper makes summary of findings.

Who are vulnerability reporters

The role of vulnerability reporters, particularly security researchers, is an increasingly important and underexplored facet of cybersecurity, despite its significance in securing digital ecosystems. Previous research has primarily focused on the technical aspects of vulnerability discovery and mitigation, while the identity, motivations, and impact of those who report vulnerabilities have received limited attention [1]. This gap in understanding is especially notable outside of structured programs, such as bug bounty initiatives. However, examining the motivations and contributions of vulnerability reporters can provide key insights for designing effective vulnerability disclosure mechanisms, improving security metrics, and fostering sustainable engagement from researchers.

Vulnerability reporters are individuals or organizations that identify and disclose security weaknesses in software, hardware, and digital services. The term encompasses a diverse set of actors, including independent security researchers, academic professionals, commercial penetration testers, and corporate security teams. Under the technical standard ISO/IEC 29147:2018 (Information technology—Security techniques—Vulnerability disclosure), the reporter is often a security researcher, but it is stressed that any individual or organisation can act as a reporter. Professional researchers can act independently or as part of an organisation. Some researchers are affiliated with universities or other academic institutions (ISO/IEC 29147, Article 5 point 5.5.4). According to the Frascati Manual [15] international methodology, research

Documents by year

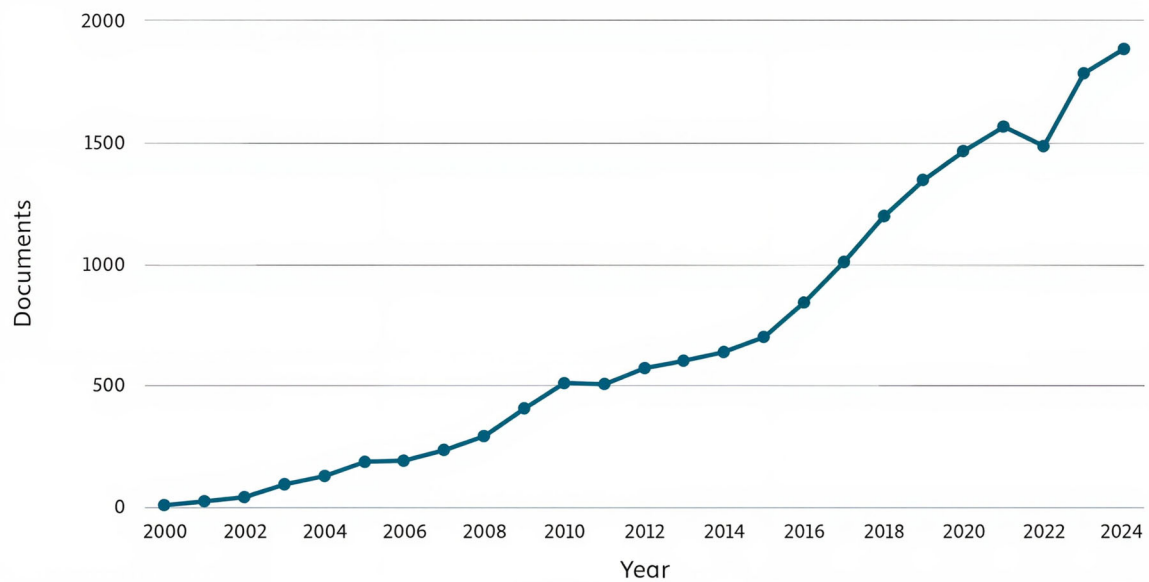


Figure 1 Number of papers relevant to security research.

organisations, and departments includes business sector, the government sector, the higher education sector (colleges, universities, and so on), as well as private nonprofit sector.

None of the assessed national legal systems, nor EU law, nor international ISO standards regulate or distinguish between the terms ethical and unethical in connection with hacking or reporting vulnerabilities. The interpretation of what is ethical and what is considered unethical often leads to disputes, as people may have differing perspectives on the ethics of hacking. Ethical hacking has become an essential part of modern cybersecurity, acting as a crucial research tool and a proactive defence strategy against cyber threats [1]. We believe that ethical hacking can qualify as security research when it adheres to a structured methodology and aims to improve cybersecurity instead of exploiting vulnerabilities for personal gain.

A recent large-scale empirical study analysed vulnerability reports from major Free/Libre and Open Source Software (FLOSS) projects, including the Linux kernel, Apache HTTP Server, Mozilla Suite, and PHP interpreter. The study revealed that vulnerability reporting is not evenly distributed among contributors. A small core group of dedicated security researchers is responsible for the majority of vulnerability reports, while a broader community of occasional contributors also plays a significant role in identifying security flaws [1].

The empirical data suggests that ~35% of vulnerability reporters are affiliated with their respective projects, meaning they have previously contributed code, reported nonsecurity bugs, or been involved in project maintenance. Furthermore, commercial security corporate research teams contribute a significant share of vulnerability reports, especially in projects like the Linux kernel, where companies such as Google, Red Hat, and Qihoo 360 are among the top contributors [1].

Bug bounty programs have become main gateway for commercial security researchers, allowing them to receive financial rewards for disclosed vulnerabilities. There is currently a bug bounty

program for over 28 000 domains [16]. The data shows that bug bounties are not the main driver of vulnerability reporting. In most analysed FLOSS projects, less than half of the reports were associated with a bounty. Some projects, e.g. Linux kernel, rely on nonbounty reporting. This suggests financial incentives do not motivate security researchers. Intrinsic motivations such as skill-building, reputation and ethics are significant.

The specialization of security researchers is another crucial aspect of vulnerability reporting. The research found that only a small number of reporters contribute across multiple FLOSS projects, indicating that vulnerability hunting is highly specialized. For instance, out of more than 2000 reporters, only 83 had reported vulnerabilities in more than 1 project, and just 14 entities contributed to 3 or more projects [16].

What is subject matter of the security research

Understanding the subject matter of cybersecurity research is essential in framing why researchers need clearer and harmonized legal protection. Security research does not focus on abstract or academic curiosities but directly addresses the vulnerabilities of technologies that shape our digital environment. By exposing weaknesses in good faith, researchers make complex technologies more transparent and help companies design safer products [17]. The subject matter of the research is not limited to probing software, even it is most well-known subfields of cybersecurity research [18]. Our network analysis of academic publications on 'security' and 'vulnerability' further supports this point. As input for our analysis, we took those papers in the Scopus database that contained the terms 'security' and 'vulnerability'. 17 924 papers were available in the Scopus database. Figure 1 shows the number of published papers by year from 2020 to 2024. As can be seen from the figure, an upward trend is visible in the long term. In

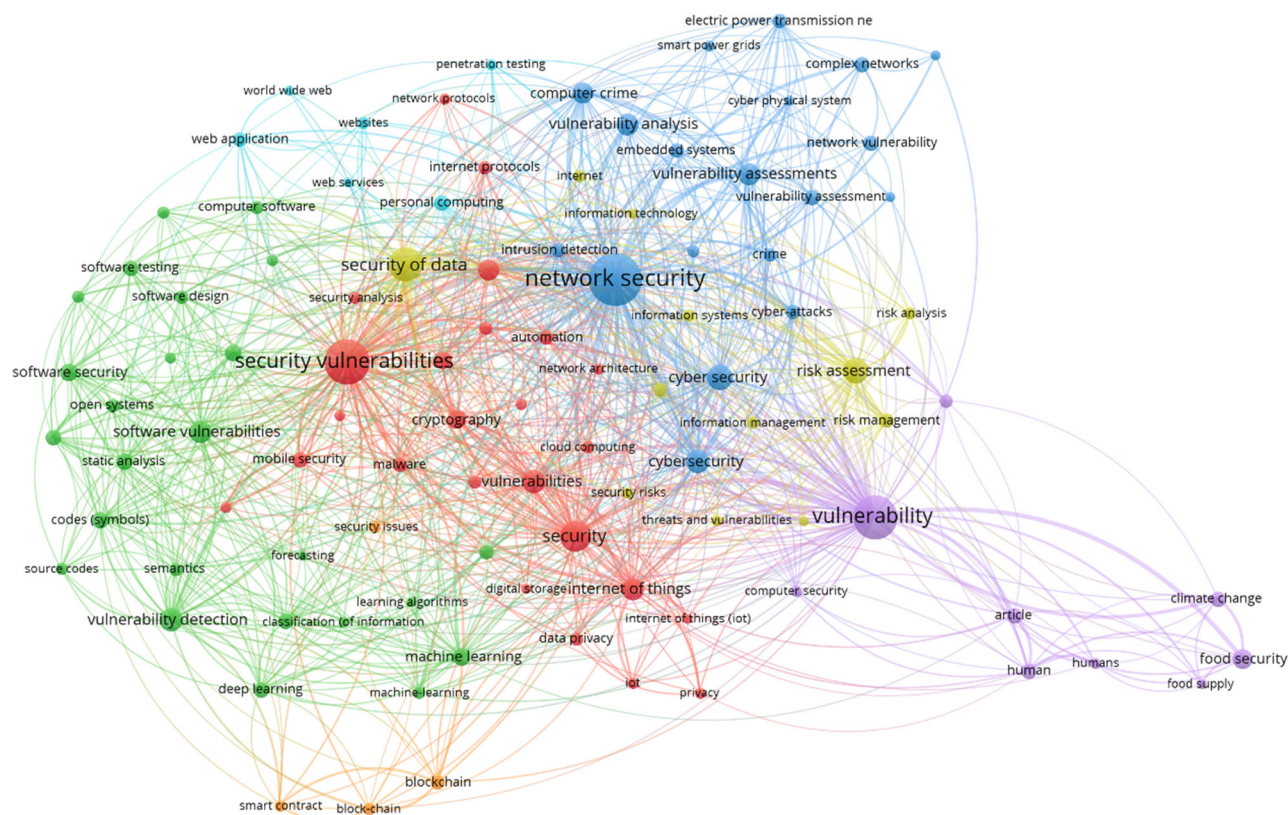


Figure 2 Visualization of the network of papers and their relationships.

contrast, there were seven papers in 2020, and 1901 were recorded in 2024. This indicates the interest of researchers from academic and other institutions in this topic.

We subsequently conducted an analysis of the abstracts and metadata of these papers using the VOSviewer tool [19]. Within this tool, we performed co-occurrence analysis—the relatedness of items is determined based on the number of documents in which they occur together. As a unit of analysis, we used all keywords, and as a counting method, we used full counting (each co-occurrence has the same weight). In total, 63 028 keywords were identified in the papers. We selected 100 keywords that occurred at least 250 times for the analysis. The top keywords relevant to security vulnerability are: network security (6495x), security of data (2716x), risk assessment (1506x), cyber security (1480x), cybersecurity (1326x), IoT (1214x), computer crime (1052x), and security systems (1070x).

In Fig. 2, we can see the result of the network analysis, and it is possible to identify seven clusters of articles relevant to research in the field of security vulnerabilities, which represent the direction of research in this area:

- 1) Cluster represents articles dealing with technical vulnerabilities (green colour)—contains keywords such as ‘access control’, ‘IoT’, and ‘hardware security’.
- 2) Cluster represents articles dealing with software vulnerabilities (red colour)—contains keywords such as ‘AI’, ‘application programs’, ‘codes’, ‘computer software’, and ‘software engineering’.

- 3) Cluster represents articles dealing with cybersecurity (blue colour)—contains keywords such as ‘network security’, ‘intrusion detection’, ‘embedded systems’, and ‘cybersecurity’.
- 4) Cluster represents articles dealing with information security (yellow colour)—contains keywords such as ‘information security’, ‘risk assessment’, and ‘security of data’.
- 5) Cluster represents articles dealing with penetration testing (turquoise colour)—contains keywords such as ‘penetration testing’, ‘web application’, and ‘web services’.
- 6) Cluster represents articles dealing with blockchain (orange colour)—contains keywords such as ‘block-chain’, ‘blockchain’, and ‘smart contract’.
- 7) The cluster represents articles dealing with the human aspect of security (purple colour)—it contains keywords such as ‘human’, ‘decision making’, and ‘computer security’.

The above network analysis of articles reveals several noteworthy observations. Research in the field of security vulnerabilities is relatively fragmented, covering topics ranging from technical vulnerabilities and software vulnerabilities, through smart contracts and IoT, to human vulnerabilities and, more recently, artificial intelligence (AI). For example, the field of AI lacks a structured process for disclosing and addressing algorithmic flaws and relies largely on an *ad hoc* approach [20]. This diversity means that legal regulation must be comprehensive and flexible, taking into account a wide range of issues and specificities. From this perspective, vulnerability research and its legal aspects should be viewed as a cross-cutting topic spanning multiple areas of cybersecurity.

The largest of the identified clusters is the first one, consisting of articles addressing technical vulnerabilities (green). It is followed

by the cluster on software vulnerabilities (red). The number of articles focusing on vulnerabilities in AI and large language models in the software vulnerability cluster is increasing. The fact that there is a separate cluster dedicated to penetration testing highlights the importance of the topic. The lack of a clear legislative framework could have a negative impact on research in penetration testing, blockchain, and related fields.

Also noteworthy is the seventh cluster, which addresses the human aspect of cybersecurity and the exploitation of people as the weakest link in security. These clusters collectively indicate the necessity of a broader, interdisciplinary approach to addressing not only technical but also legal aspects of cybersecurity.

The network analysis revealed a lack of dedicated coverage of legal aspects of security vulnerabilities. The phrase ‘laws and legislation’ appeared in only 62 articles, and the keyword ‘law’ appeared in just 9. This is a comparatively small number, considering the growing trend in research in this field. This suggests that the legal aspects of security research are not yet fully integrated. As security research grows in importance, an unclear legal environment limits researchers’ efforts to protect personal devices and vital infrastructure. As noted by Park and Albert [21] ‘especially in a fast-changing context like technology, it is typical for the law to remain unclear on edge cases until tested by litigation’.

The network analysis of articles on security vulnerabilities thus serves as empirical evidence that, on the one hand, demonstrates the breadth and complexity of the field, and, on the other hand, reveals gaps in the current legal framework. This analysis merely confirms prior research conducted by the team led by Sotirios Katsikeas. They analysed the most-cited scientific articles of 98 373 authors in the cybersecurity and information security domains and identified 12 research communities, which they ranked according to their current activity level. As they observe in their study, these research communities appear to place greater emphasis on cryptography, quantum cryptography, information hiding, and biometrics, at the expense of other topics, including risk management and governance, as well as laws and regulations [22].

The foregoing analysis demonstrates that, although cybersecurity research increasingly draws upon interdisciplinary methods, the legal dimension of such research remains notably underdeveloped. In light of these findings, the following section turns to an examination of the legal risks associated with cybersecurity research.

Legal risks of cybersecurity research

The act of probing systems even with the good intentions can trigger serious legal consequences under a fragmented legal landscape in the EU. These challenges are enabled by an overall legal environment that does not sufficiently protect security researchers and by the behaviour of many vulnerability owners threatening security researchers with legal proceedings when receiving reports [23].

The ENISA highlighted that legal uncertainty remains one of the most significant obstacles to widespread adoption of CVD policies [24]. A person could decide to do nothing, exploit the vulnerability or sell it at an underground market, disclose the vulnerability publicly, or disclose the vulnerability privately by using CVD. The motives of the individual actor will directly shape their cost-benefit

analyses regarding the organizational and criminal justice system responses to such a disclosure [25].

Freiling [26] emphasizes that, while CVD significantly reduces the risks to potentially affected users, it presents numerous practical and legal challenges for researchers, particularly the lack of legal education in computer-science curricula and the asymmetric communication dynamics between individual researchers and corporate actors. IT-security research has demonstrably improved overall cybersecurity levels and should therefore be supported through clearer legal norms, especially where researchers make responsible CVD-related decisions [26].

Researchers can face criminal liability for unauthorised access even if they mean to improve security. National laws often fail to exempt good-faith research or ethical hacking. There are also risks under copyright law, where reverse-engineering or analysing code to find flaws could be treated as infringement. Data protection law brings risks where vulnerabilities involve access to personal data. Contract law brings risks from terms of service, license agreements, or private bug bounty programs that can expose researchers to civil liability. Export controls may restrict the use or dissemination of dual-use cybersecurity tools used in research.

These abstract legal concerns have materialized into real prosecutions and threats in various EU countries. The following cases demonstrate the practical and reputational risks involved.

Researchers of Radboud University sued in the Netherlands (2008)

Radboud opens the gates [27]. Radboud University case involving the MIFARE Classic chip is widely regarded as one of the first prominent and documented cases in the EU, where legal threats were used to hinder legitimate academic security research. It remains a landmark example of the tension between responsible disclosure and intellectual property or commercial interests, particularly before the development of more mature CVD frameworks across the EU.

In 2008, researchers from Radboud University in the Netherlands discovered critical security vulnerabilities in the MIFARE Classic chip, widely used in contactless smart cards (e.g. public transport and access cards). Their findings revealed weaknesses that could allow cloning of cards and unauthorized access [28]. However, before their findings could be presented at a major security conference, NXP Semiconductors (the chip manufacturer) filed a lawsuit requesting a preliminary injunction from a Dutch court, temporarily barring the researchers from publishing the technical details. NXP claimed that the publication would *inter alia* violate their intellectual property rights to algorithm. The court ruled in favour of the researchers, emphasizing that the public interest in cybersecurity and freedom of expression outweighed the company’s intellectual property rights. This ruling established that security research contributing to cybersecurity improvements should be protected, reinforcing the legitimacy of responsible disclosure.

University research blocked in the UK (2013)

In the following case group of researchers from Radboud University in the Netherlands and University of Birmingham in the UK,

faced legal threats after discovering vulnerabilities in keyless entry systems used by Volkswagen and other manufacturers. The researchers were initially banned from publishing their findings due to alleged fears of facilitating criminal misuse. The incident raised concerns about academic freedom and the right to publish security research. Eventually, the team presented their work at USENIX Security Symposium, two years later [29].

Maltese students and lecturer prosecuted (2023)

In Malta, three university students and lecturer were prosecuted after revealing security vulnerabilities of the largest student application, FreeHour. The students were all accused of gaining unauthorised access to the app, and one of them was also charged with making an alteration to the app. Lecturer was charged as an accomplice, after proofreading a certain email sent to Free-hour by the students. The case raised public outcry among academics, politics, and cybersecurity professionals [30]. Eventually, all have been granted a Presidential pardon under the Constitution of Malta in July 2025 [31].

IT consultant prosecuted in Germany (2024)

In 2024, the Regional Court of Aachen confirmed the conviction of a freelance German IT consultant for unauthorized access to data under Section 202a of the German Criminal Code [32]. The consultant had discovered a severe vulnerability in the software of Modern Solution, a company providing online store infrastructure, which allowed access to the personal data of nearly 700 000 users. While the vulnerability was responsibly reported and later fixed, the expert published details of the issue in a professional blog. Instead of acknowledging the disclosure, the company filed a criminal complaint, leading to a police raid and seizure of the researcher's equipment.

The prosecution argued that the consultant used a password embedded in the software source code to access the company's database, and the court ultimately held that the act constituted criminal access, even though no technical barriers were circumvented. Key to the court's ruling were screenshots taken by the researcher as evidence of the vulnerability. The court emphasized that continued access and documentation of sensitive user data, even for disclosure purposes, crossed the legal threshold of unauthorized access. The court emphasized that the defendant could have avoided criminal liability if he had terminated the access the moment, he realized that he could access the data of customers that he should not have seen. However, in a positive development, Germany's Federal Ministry of Justice introduced a draft amendment to exempt good faith security researchers from liability under Sections 202a, 202b, and 303a of the German Criminal Code (see the section 'Comparative legal overview of cyber security safe harbours in EU').

Why some companies say no to researchers

Organisations, service providers and vendors often block cybersecurity researchers from inspecting their systems. We believe this

is due to three reasons. First, they worry about the legal consequences. If researchers find problems, they might face legal issues like criminal charges, copyright infringement, or data protection violations. This would make them less willing to work with researchers in future. Second, contractual and reputational risks also deter collaboration. Organizations may worry researchers could exceed preagreed scope or inadvertently expose systems during testing. The same applies to publication of the presentations, research articles, on details of the discovered vulnerability. Lastly, vendors may not have the right processes or may not be able to trust researchers. Organisations may find CVD features and services burdensome to manage internally and opt to use a platform to help implement them, although some programme operators note the prohibitively high costs associated with platform usage [33, 34]. Unless the law explicitly clarifies liability protections and actively supports responsive processes, many firms will continue to favour existing legal ambiguity over vulnerability disclosure initiatives.

Legal and ethical boundaries of good-faith security research

There are no specific ethical behaviour standards for cybersecurity research [18]. The ethical standards described in this section are those that are most pertinent to cybersecurity research. However, these standards do not cover all situations of cybersecurity research. Therefore, while it is good to follow, these standards do not assume that uncovered scenarios are automatically ethical.

This absence of a comprehensive ethical framework is critically examined by Macnish and van der Ham [35]. They identify significant discrepancies in how ethics are governed within different communities of cybersecurity researchers. Academic researchers typically rely on Research Ethics Boards (REBs) to assess their work, but the authors argue that many REBs lack the necessary technical knowledge to provide meaningful ethical oversight in cybersecurity contexts. Conversely, practitioners and corporate researchers often operate without any formal ethical review process at all. Loi and Christen [36] further present several ethical frameworks to approach the ethical challenges raised by enforcing cybersecurity, namely the *principlist* approach and a *rights-based* approach rooted in EU law. Given that cybersecurity harms and benefits often involve risk, they argue for incorporating *ethics of risk*, supplemented by consequentialist, deontological, contractualist, and contextual integrity theories to assess the broader ethical impact of cybersecurity practices [36].

Right to research cybersecurity vulnerabilities

As van Daalen [2] argues, information security and cybersecurity is not static but an ongoing process of identifying and mitigating vulnerabilities. Legal frameworks must adapt to this iterative process and recognize security research as a fundamental right under the right to science and freedom of communication [2].

The right to science is a recognized human right under Article 15 of the International Covenant on Economic, Social and Cultural Rights (ICESCR) and Article 13 of the EU Charter of Fundamental

Rights (CFR). These provisions establish the principle that scientific inquiry should be protected and promoted, ensuring that researchers can freely investigate, analyse, and disclose security vulnerabilities.

Scientific research is built on free inquiry and the iterative exchange of knowledge. This principle is particularly relevant to cybersecurity, where research follows a continuous cycle of identifying vulnerabilities, testing security systems, and improving defences [2]. If security researchers are prevented from testing and disclosing vulnerabilities, it hinders cybersecurity progress and weakens public defence mechanisms.

Under Article 15 of the ICESCR, states must ensure that scientific knowledge is accessible to the public. This includes allowing security researchers to share their findings with vendors, government agencies, and the broader cybersecurity community.

Many security researchers encounter legal challenges when disclosing vulnerabilities, as van Daalen points out. They often face lawsuits for allegedly violating terms of service agreements with software providers or may be criminally charged for unauthorized access. As a result, some researchers are hindered from publishing their findings.

The freedom of communication is protected under Article 10 of the European Convention on Human Rights (ECHR) and Article 11 of the CFR. These provisions safeguard the right to seek, receive, and impart information, including security research findings. The European Court of Human Rights has consistently held that restrictions on information sharing must be proportionate and serve a legitimate public interest.

Cybersecurity vulnerabilities pose a significant risk to public safety, affecting critical infrastructure, financial institutions (e.g. banks and stock exchanges), and personal data protection (e.g. medical records and identity theft prevention). Given these stakes, the disclosure of security vulnerabilities serves a clear public interest. Courts have recognized that information contributing to public safety deserves heightened protection under freedom of expression [2, 37, 38].

Good-faith security research

Good-faith security research is critical to improving the systems we rely on in every part of our lives, from cars to the power grid. In recent years, particularly in the USA, much progress has been made in improving the relationship between researchers, government, and information system owners. Coordinated vulnerability reporting programs have emerged as a standard practice for members of the public, who conduct security research and report identified vulnerabilities to organizations so that they can be patched in a timely manner [39]. One example is the vehicle manufacturer Tesla, which allows researchers to register as a preapproved good-faith security researcher and register a Tesla vehicle as a research-registered vehicle [40].

To protect researchers, we propose defining ‘good-faith security research’ as a general exception or safe harbour [12]. This definition should include minimizing harm to the rights of holder to the computer program and efforts to communicate any discovered vulnerabilities to the information system’s owner as early as possible. Conversely, activities motivated solely by profit, such as using any identified vulnerabilities for commercial purposes before disclosure, should not be allowed.

Cyber security safe harbours in selected international and European cybercrime law

Budapest Cybercrime Convention

For the purposes of this paper, the provisions of the Convention on Cybercrime of the Council of Europe ETS number 185 (2001) (Budapest Convention) that address offences against the confidentiality, integrity, and availability of computer data and systems are of particular relevance. These categories of cybercrime lie at the intersection with cybersecurity research, particularly in relation to the detection and analysis of vulnerabilities. The legal framing of these provisions and the extent to which they permit a nuanced interpretation of their elements is crucial in delineating the boundary between security research and unlawful hacking.

Article 2, first alinea of the Budapest Convention makes it unlawful to access a computer system if it is committed intentionally, whereby unauthorised access to the computer system as a whole or in part has been made. This means that four conditions must be met in order for an unlawful access to be considered criminal under the Budapest Convention: (i) that the person should have entered the system intentionally, (ii) that the person should have actually accessed the computer system, (iii) that the access should relate to either the whole or part of the computer system, and (iv) that the person should not have had the right to access the system.

However, the Budapest Convention allows for the mandatory elements for the fulfilment of the offence to be extended by an additional condition. Under Article 2, second alinea, a member to the Budapest Convention may provide for the requirement that such an offence must be committed by a breach of security with intent to obtain computer data, or with other *dishonest intent*, or in relation to a computer system linked to another computer system. Thus, the Budapest Convention allows its members to formulate the elements of an offence so that the offence is committed by a breach of security measures with intent to obtain computer data or with other dishonest intent, or in relation to a computer system that is connected to another computer system.

Similar possibilities for a more targeted definition of the subjective element of the unlawful act, which allows to filter out the actions of a good-faith security researcher, are only provided for by other provisions of the Budapest Convention.

Article 3 on unlawful interception allows states to require a dishonest intent before imposing liability, ensuring that researchers testing encryption or communication channels are not punished when their purpose is to improve security. Similarly, Article 4 on data interference permits states to require substantial damage as a condition of liability, enabling a distinction between malicious alteration of data and testing that does cause no or minimal harm. Article 6 explicitly exempts the legitimate use of penetration testing tools from the offence of ‘misuse of equipment’, while Articles 7 and 8 on forgery and fraud allow members to require fraudulent intent, leaving room for lawful testing of authentication or transactional systems.

Thus, the Budapest Convention provides scope for taking into account the good faith conduct of security researchers, in particular through mechanisms that allow members to modify criminal provisions to apply only to conduct with dishonest intent or fraudulent intent. This approach allows for a clearer carve-out of the

activities of ethical hacking and security research. Thus, all members to the Budapest Convention could use these provisions to establish clear boundaries between harmful and legitimate cyber research.

EU directive on attacks against information systems

The Directive 2013/40/EU of the European Parliament and of the Council of 12 August 2013 on attacks against information systems (Directive on attacks against information systems) largely mirrors the Budapest Convention in terms of what constitutes unlawful access to an information system but explicitly distinguishes malicious activities from legitimate security research. The Directive on attacks against information systems explicitly states in Recital 17 that this ‘Directive does not impose criminal liability where the objective criteria of the offences laid down in this Directive are met but the acts are committed without criminal intent, for instance where a person does not know that access was unauthorised or in the case of mandated testing or protection of information systems, such as where a person is assigned by a company or vendor to test the strength of its security system.’ This approach is also essential to support the protection of security researchers who are dedicated to detecting vulnerabilities.

Further, unlike the Budapest Convention, in Recital 11 and Articles 3–7, the Directive on attacks against information systems allows for the application of the corrective, and criminalises only those acts ‘which are not minor’. For example, a case may be considered minor where the damage caused by the unlawful act and/or the risk to public or private interests, such as the integrity of a computer system or computer data, or the integrity, rights or other interests of a person, are insignificant or of such a nature that the imposition of a criminal sanction within the statutory limit or the establishment of criminal liability is not necessary.

Further, unlike the Budapest Convention, the Directive in Article 2(e) contains a definition of the term ‘without right’. Without right means conduct, including access, interference, or interception, which is not authorised by the owner or by another right holder of the system or of part of it, or not permitted under national law. This clearly leaves room for the authorisation to carry out security research to be regulated in national law, for example by explicitly defining ‘good-faith security research’ as a permitted activity.

Both the Budapest Convention and Directive appear to implicitly acknowledge the legitimacy of ‘ethical’ hacking, primarily by emphasizing the role of intent (such as dishonest or direct intent) rather than relying solely on objective elements of a crime [41].

United Nations Convention Against Cybercrime

United Nations Convention Against Cybercrime (UN Convention) was adopted recently in December 2024 and as of now it is not binding in the EU [42] (on 16 July 2025, the European Commission proposed to the Council to sign and conclude the UN Convention. If adopted by the Council, it will need also the consent of the European Parliament). While the UN Convention (Article 53/3, e). recognizes the contributions of the legitimate activities of security researchers when intended to strengthen and improve the security

of service providers’ products, services, and customers, it aims to enhance international cooperation to combat malicious hacking, it raises serious concerns for those involved in security research and ethical hacking [43]. The UN Convention have drawn criticism due to fears that overly broad criminalisation may endanger the lawful work of security researchers, investigative journalists, and others acting in the public interest [44]. Civil society groups and business stakeholders have consistently cautioned that the treaty must include safeguards against such misuse, such as requiring a higher threshold of intent or incorporating explicit public interest exceptions [45, 46]. The UN Convention’s broad terminology (Articles 7–11) introduced significant uncertainty, particularly by requiring signatories to criminalize unauthorized access to any part of a computer system performed ‘without right’. Likewise, the prohibition on intentionally damaging, deleting, or altering computer data ‘without right’ poses risks for research, where data manipulation is often a controlled part of security evaluations [43].

Both the UN Convention and the Budapest Convention however define core cyber crimes, such as illegal access, in similar terms and allow states to ‘require’ dishonest or criminal intent. The UN Convention is broader in scope than the Budapest Convention, addressing additional areas such as money laundering, content-related crimes, and international cooperation measures beyond the core cyber-dependent offences. On the other side, the UN Convention omits crimes related to copyright infringement, which are included in the Budapest Convention (Article 10).

The UN Convention uses broader definitions, replacing terms like ‘computer system’ with ‘information and communications technology (ICT) systems’ and ‘computer data’ with ‘electronic data’. This broader scope may reflect current technology more accurately but may also create greater legal uncertainty, especially when applied to research involving embedded systems, IoT, or cross-device communications.

Both conventions require the application of safeguards, proportionality, and procedural guarantees (Budapest Convention Article 15, UN Convention Article 24). However, the Budapest Convention refers explicitly to the ECHR, the 1966 United Nations International Covenant on Civil and Political Rights and other international treaties, whereas the UN Convention uses more general references to ‘international human rights law’. The UN Convention also defers too much to national laws, which may lack adequate human rights protections. This difference is critical. In jurisdictions where human rights protections are weak, the vague language of the UN Convention may fail to provide sufficient protection for researchers. The Budapest Convention, by contrast, connects its safeguards in the European legal space, offering more specific procedural and legal standards. Importantly, legal protection of security research is vital to ensuring robust cybersecurity. As we analysed above in this paper, this process is fundamentally linked to the *right to science* as protected under Article 15 of the ICESCR and Article 13 of the CFR.

The Budapest Convention offers clearer definition of crimes and more consistent language regarding intent, safeguards, and procedural fairness. It could offer clearer exemptions for security research, but the framework enables members to design legal environments that distinguish between malicious actors and good-faith security researchers or whistleblowers. Importantly, procedural safeguards are tied to established international human rights instruments, reinforcing legal certainty and proportionality.

However, the UN Convention relies heavily on domestic interpretation, which could result in criminalisation of research activity.

Comparative legal overview of cyber security safe harbours in EU

Bottom-up v a top-down approach

This part of the paper investigates national approaches to cybersecurity research and CVD across a selected group of EU Member States, including the Netherlands, Belgium, France, Germany, Italy, Spain, Poland, Czechia, Slovakia, Malta along with two other countries, the UK and the USA. These countries were selected based on the diversity of their legal frameworks, the maturity of their cybersecurity ecosystems, and their relevance in shaping CVD practices in Europe and beyond.

So far, authors used different comparative approaches to classify countries regarding the protection of cybersecurity research. One method groups countries by the type of legal safeguard provided. Schröder [47] divides country regimes to (1) no specific legal rules, relying on general provisions and discretion; (2) procedural-only protections; (3) a mix of procedural and substantive safeguards; and (4) substantive criminal or civil law exemptions. The second approach focuses on the legal logic behind the protections, i.e. by assessing intent or motivation, as a form of whistleblowing, providing objective safe harbours and so on [48].

To facilitate structured comparison, we decided to categorize the selected countries not merely by legal branches but by the regulatory architecture underpinning their treatment of security researchers and vulnerability disclosure, namely by a bottom-up v a top-down approach.

Bottom-up, trust-based models with limited formal regulation

The Netherlands is the primary example of a permissive, researcher-friendly environment based on informal coordination and voluntary policies, even though there is no explicit statutory provision recognizing ethical hacking. Instead, the Dutch Public Prosecution Service issued guidelines in 2013 that outline principles for evaluating the criminal liability of security researchers engaged in responsible disclosure [28]. While Dutch criminal law does not formally exempt security researchers from prosecution, these guidelines provide a prosecutorial discretion mechanism that effectively protects researchers acting in good faith. The National Cyber Security Centre (NCSC) institutionalized CVD practices by publishing guidelines in 2013 (revised in 2018), which government agencies and private companies could adopt [49]. This policy encourages security researchers to report vulnerabilities responsibly and ensures that public and private entities engage constructively with researchers. The Netherlands consider having followed a bottom-up approach as the most important success factor for their CVD policy [24]. The country noticed that if companies, institutions or organisations are not faithful to individuals reporting vulnerabilities, it is difficult to force them to implement/adopt a CVD system. Hence, rather than imposing companies to establish a CVD policy (top-down approach), it is much more fruitful to stimulate an ecosystem in which researchers/hackers know that they are safeguarded judicially and that they are acknowledged by society.

Top-down, authority-driven models with procedural legal provisions

This category includes countries, where national cybersecurity authorities and/or prosecutors play a leading role in managing vulnerability disclosures, without fully decriminalizing research or embedding safe harbour provisions in law. This model emphasises formal structures and centralised coordination but may still expose researchers to legal uncertainty. These include:

France

In France, the French Cybersecurity Agency (ANSSI) acts as the gatekeeper for disclosures. Though there is no formal immunity in the Penal Code, the ANSSI framework facilitates responsible disclosure and serves as a trusted intermediary between researchers and the state. Legal protection for security researchers under Article L.2321–4 of the French Code de la Défense, introduced through the 2016 Digital Republic Act, creates a safe harbour for vulnerability reporters when two legal criteria are strictly met, constituting a statutory derogation to French criminal law. Researchers who disclose security vulnerabilities in good faith exclusively to the ANSSI are shielded from prosecution. However, this statutory protection applies only if researchers act with genuine intent to improve cybersecurity and report vulnerabilities solely to ANSSI. If these conditions are met ANSSI is authorized to anonymize the researcher's identity when handling vulnerability reports. Despite this statutory safe harbour, affected companies still retain the right to file complaints, though ANSSI's role in mediating such disputes reduces the risk of retaliation [50].

Slovakia and Czechia

In both countries, security authorities, Slovak National Security Authority (NBÚ) and Czech National Cyber and Information Security Agency (NÚKIB) maintain control over incident reporting and now also serve as central points for regulated security research.

Both Slovakia and Czechia are waiting for publication of their national CVD policy, however they do not have (nor plan to have) legal safe harbours for security researchers. So far, the Slovak NBÚ has adopted a Vulnerability Reporting Guide that outlines recommended procedures for researchers and affected entities but lacks legal enforceability [51].

The Slovak NBÚ may however provide certain level of legal protection to good-faith security researchers under confidentiality obligation in connection with cybersecurity incident reporting and vulnerability disclosures [The Slovak Act number 69/2018 Coll. Cybersecurity Act as amended (Section 12)]. The NBÚ's commitment to maintaining confidentiality may act as a practical shield that helps protect researchers from unwanted exposure of their identities and potential liability. In the area of vulnerability disclosure, the national CSIRT unit (NCSC SK-CERT), to publish vulnerabilities or prevent their misuse, performs the role of coordinator in matters of communication about detected or reported vulnerabilities (Section 6 of the Act Number 69/2018 Coll. On Cybersecurity as amended).

The Slovak law contains security research by state authorities. According to Section 23a (2) of the Act Number 95/2019 Coll. on Information Technologies in Public Administration, the Slovak government unit CSIRT.SK may conduct regular vulnerability assessments of public administration services. The CSIRT.SK uses the Achilles system to perform its authority [52]. This system automatically tests all publicly available and registered public administration systems. The NIS2 sets out a similar provision in Article 11, when it allows all CSIRTs to carry out active, nonintrusive

scanning of publicly accessible networks and information systems of key and important entities. Such scanning is carried out to detect vulnerable or insecurely configured networks and information systems and inform the affected entities. Such scanning must not have a negative impact on the functioning of the entities' services. In addition to the above, Section 23 (5) of the Act on Information Technologies in Public Administration contains an obligation for public organizations to publish rules for reporting vulnerabilities on their website.

In the Czechia, the NÚKIB is finalizing the national CVD policy [53]. Under the recently adopted new Cybersecurity Act (CSA), NÚKIB is positioned to assume a leading role in the area of CVD, and the national CERT team, operating under NÚKIB, will be entrusted not only with receiving and managing reports of vulnerabilities but also with actively searching for and evaluating them. This development marks a shift from a primarily reactive to a more proactive stance in the national cybersecurity framework. In the context of 'legitimate' discovery activities, however negligent interference with data or information systems may be penalized under the Czech Criminal Code, suggesting that researchers may still be prosecuted in the absence of clear safe harbours, even if their actions were not malicious or deliberate [14].

Malta has adopted national CVD policy in 2024, which does not however, purport to amend, replace or prevail of any applicable laws in particular the Criminal Code [54]. The policy requires that such security researchers or participants notify the CSIRT Malta within the Malta Critical Infrastructure Directorate (MaltaCIPD). The policy introduces a registry of researchers at the MaltaCIPD, demanding that researcher should notified with the MaltaCIPD [54]. This is a novel formalization step not found in most EU national CVD frameworks. It likely serves two goals creating a vetted, trusted pool of eligible researchers, tracking and regulating participation to prevent abuse or shield only verified actors.

Italy and Spain reflect similar dynamics. Italy's National Cybersecurity Agency (ACN) has taken a proactive and supportive stance toward cybersecurity research through its *Research and Innovation Agenda 2023–2026*, which emphasizes the importance of fostering a resilient and secure digital environment [55]. However, it does not mention CVD nor security researchers. It focuses on broader cybersecurity priorities but does not include any reference to CVD processes, bug bounties, or the status and protections of independent security researchers. Italy did not so far adopt a national policy on CVD [48]. As Italy does not yet have a national framework for the research and disclosure of security vulnerabilities, those who engage in 'ethical' IT research, intrusions, or attacks (and even those who commission them) risk falling within the scope of the relevant criminal provisions, without being able to claim any special exemption [48]. As of now, Italy has adopted only one explicit legal exemption under which hacking activities are not punishable. Under Article 2-bis of Law Decree 105/2023 grants police officers immunity from criminal liability for acts such as unlawful access, data interference, and system interference when these actions are carried out as part of authorized undercover operations aimed at preventing or combating terrorism or cyber-crime targeting critical infrastructures [48]. This exemption, however, is narrowly tailored and applies exclusively to law enforcement, offering no comparable legal protection for civilian security researchers acting in good faith.

Spain does not have a formal national CVD policy. However, a vulnerability disclosure policy framework has been partially es-

tablished at the level of CCN-CERT and National Institute of Cybersecurity of Spain (INCIBE-CERT) [24]. In Spain, the implementation of a CVD framework faces several obstacles. Under the current Article 197 bis of the Spanish Criminal Code, even unauthorized access without further malicious intent constitutes a criminal offence. As a result, if a researcher was to notify a company or public institution about a discovered vulnerability, such communication could be used as evidence of unlawful access and lead to prosecution. This legal uncertainty deters ethical hackers from reporting vulnerabilities, if they do so at all, they often choose to remain anonymous. To establish a functioning CVD system, Spain would need to amend its criminal law to provide explicit exemptions from liability for researchers who report vulnerabilities in good faith [41].

UK

The UK government is currently preparing legislation that will mandate manufacturers of connected smart devices to provide a public point of contact as part of their vulnerability disclosure policies, aligning with best practices outlined in guidance from the NCSC [56]. At the same time, efforts are intensifying to reform outdated legal frameworks such as the Computer Misuse Act 1990 (CMA), which has long been criticized for failing to protect cybersecurity professionals engaging in good-faith research. The CyberUp Campaign, backed by industry stakeholders and cross-party parliamentary support, advocates for introducing a statutory legal defence for security professionals under the forthcoming Crime and Policing Bill [57]. Exposing to prosecution is evident also from the UK Home Office recently launched vulnerability reporting mechanism using the HackerOne platform. The guidance issued by the Home Office explicitly warns that researchers must not violate 'any applicable law or regulations', despite acting in good faith and complying with the disclosure policy [58].

Top-down, hard-law models with substantive legal provisions

Countries in this group have introduced or are in the process of adopting binding legal rules that offer security researchers defined protection under national law. This group may be subdivided based on whether the substantive legal provisions on safe harbour lay in criminal law or in administrative law. This includes:

Poland

CVD service started in 2023 at CSIRT NASK (which includes CERT.PL) [59]. Poland stands out among EU Member States for explicitly codifying an exemption from criminal liability for good-faith cybersecurity research directly in its Criminal Code. The Polish Criminal Code contains key provisions relevant to this area, including Articles 267 through 269c. Notably, Article 269c introduces a conditional exemption from punishment for persons who engage in activities such as unauthorized access (Article 267 Section 2) or interference with computer systems (Article 269a), provided that their actions are solely aimed at securing information or ICT systems, or developing methods for such security. Additionally, the researcher must promptly notify the system or network administrator of the detected threats, and no public or private interests may be harmed as a result of their actions. While progressive, this legal construction also raises interpretive challenges. The provision leaves significant discretion in defining terms like 'exclusivity of purpose', 'immediate notification', and 'no harm', thereby introducing legal uncertainty for researchers. For example, it

remains unclear whether notification is required at the moment of initial suspicion or only after a comprehensive analysis has confirmed the vulnerability [60].

Moreover, the law applies even in the absence of a contractual relationship or consent from the system owner, which is rare in comparative perspective. According to Polish legal scholars, only a narrow interpretation of the exemption can safeguard against misuse [61]. Notification must be both prompt and meaningful, ideally via direct and secure channels such as telephone or verified email, and not through public forums. Furthermore, ‘no harm’ includes not only technical integrity but also reputational and functional aspects; the system operator must not suffer any adverse consequences from the researcher’s actions, except for reasonable security improvements [61].

Belgium

Belgium adopted CVD policy and the Centre for Cybersecurity Belgium (CCB) is the designated CVD coordinator [62]. Belgium’s approach to protecting security researchers, known as ‘vulnerability reporters’, represents a significant shift towards the decriminalization of vulnerability reporters. In February 2023, a new whistleblower act (Whistleblower act) came into force in Belgium. The Whistleblower act also amended the Belgian Act of 7 April 2019 on the security of network and information systems in the public interest, adding a new Article 62(1), which reads that ‘any natural or legal person may report the existence of a potential vulnerability to the national CSIRT (note: CCB)’. Reports must be submitted in writing via the procedure on the national CSIRT website. Under the new Article 62(2), reporting persons are exempt from liability if they act without fraudulent intent, notify the responsible organization and CSIRT promptly, limit their actions to what is necessary to verify the vulnerability, and refrain from disclosing information without CSIRT’s consent.

If the notifier became aware of the vulnerability in the course of performing their work duties, they are not liable for breach of confidentiality with regard to information necessary for reporting the vulnerability, provided that the information was disclosed exclusively to the national CSIRT. This protects, for example, internal security staff or employees of ICT service providers from labour or civil law sanctions.

In addition to the above, the Whistleblower act also expressly regulates the limitation of the scope of exclusion of liability. Liability for any other act or omission not directly related to the notification or not meeting the set conditions shall be assessed under generally applicable law. This means that only narrowly defined actions in accordance with CVD procedures are protected, and if a researcher, for example, manipulates data, discloses a vulnerability in an uncoordinated manner, or exceeds the necessary scope, they may be prosecuted.

Germany

The German Federal Office for Information Security (BSI) adopted a CVD policy that outlines how security researchers should report vulnerabilities they discover [63]. The BSI policy should be regarded as the German national policy [24]. The BSI acts as a coordinator for CVD process. This concerns IT products, systems, or services used by the federal administration on the one hand and by manufacturers, product managers, and project managers on the other. If they fail to respond to the relevant reports, the BSI provides support in accordance with BSI CVD guidelines. According to the BSI’s 2024 report, a total of 387 CVDs (including zero-day vulnerabilities) were handled. This development confirms the BSI’s

increased activities in this area, the BSI’s CVD process has become significantly more relevant and visible in recent months through the provision of a vulnerability reporting form, the publication of CVD guidelines, and initial incentives to report discoveries to the BSI, such as the Hall of Fame for vulnerability researchers [64].

Germany has been considering the introduction of a legislative safe harbour for good-faith security researchers under the German Criminal Code (*Strafgesetzbuch*). Draft to amend the Criminal Code published in November 2024, explicitly exempted good-faith security researchers from prosecution under core computer-related offenses, namely data spying (Section 202a), data interception (Section 202b), and data alteration (Section 303a) of the German Criminal Code. Under Section 202a(3) of the draft, researchers acting solely to identify security vulnerabilities and reporting them responsibly to the system operator, vendor, or the German Federal Office for Information Security (BSI), provided that their access was necessary to identify the vulnerability, would be immune from criminal liability [65]. However, no formal bill has yet been submitted. The current coalition agreement nonetheless reaffirms the government’s intention to ‘create legal certainty for IT security research within computer criminal law, while preventing opportunities for misuse’ [66]. Security researchers are pushing for the draft to be implemented in the new legislative period [67].

The USA

The solution in the USA for typical computer crimes can only be understood by looking at US copyright law. A substantive law solution was chosen in copyright law [47].

In 1998, the US Congress adopted the DMCA to modernize copyright law for the digital era. A key provision, Section 1201, prohibits circumventing technological protection measures (TPMs), such as encryption, authentication gates, or region locks, that control access to copyrighted works, including software. Under this provision, circumventing TPMs without the copyright holder’s consent can result in civil or criminal liability, even if done for purposes of independent security research.

To mitigate these legal risks, the US Copyright Office periodically grants temporary exemptions from Section 1201, valid for 3-year terms. In response to sustained advocacy from the research and cybersecurity communities, the Copyright Office in 2024 granted an exemption for good-faith security research [68]. This exemption allows researchers to bypass TPMs without the copyright owner’s consent, provided the activity meets strict conditions: it must occur on a lawfully acquired device or system or with the owner’s authorization, and the purpose must be solely to test, investigate, or fix security vulnerabilities. The activity must not harm individuals or the public, and the findings must be used primarily to promote the security of a class of devices or systems, not to facilitate copyright infringement. However, it remains temporary, requiring renewal every three years.

What constitutes good faith security research is defined in revised 37 Code of Federal Regulations Section 201.40(b) (18) (ii). ‘Good-faith security research’ means

- (i) accessing a computer program solely for purposes of good-faith testing, investigation, and/or correction of a security flaw or vulnerability,
- (ii) where such activity is carried out in an environment designed to avoid any harm to individuals or the public, and

(iii) where the information derived from the activity is used primarily to promote the security or safety of the class of devices or machines on which the computer program operates, or those who use such devices or machines, and is not used or maintained in a manner that facilitates copyright infringement.

In 2021 the US Supreme Court limited the scope of the Computer Fraud and Abuse Act (CFAA) in a useful way in *Van Buren v. United States* [69], and the following year the Department of Justice announced a charging policy to avoid charging good-faith security research under the CFAA [70]. Researchers however still face potential exposure under state-level antifraud statutes. It is unclear to what degree the policy represents a change in how DOJ will approach cases. Nor can security researchers rely on the guidance for concrete assurances against liability, because the policy revision has no effect on civil CFAA liability or state laws that provide for criminal or civil liability for unauthorized access to computer systems. Researchers however still face potential exposure under state-level antifraud statutes, namely when using deception-based methods (e.g. social engineering, phishing, but also attacking or auditing AI systems, and research involving legal identification) [71].

Copyright law perspective of safe harbour

Copyright frameworks, primarily designed to protect intellectual property, often fail to differentiate between malicious hacking and security research conducted in good faith. The Court of Justice of the European Union (CJEU) provides important guidance for the legal boundaries of reverse engineering in the context of security research. In its judgment in *Top System SA v. Belgian State* (CJEU, C-13/20 *Top System SA inc. v Belgian state*. ECLI:EU:C:2021:811), the CJEU clarified that under Article 5(1) of Directive 91/250/EEC (now codified by Directive 2009/24/EC), the lawful purchaser of a computer program is entitled to decompile that program without the consent of the rights holder if such decompilation is necessary to correct errors affecting the functioning of the software, including where the correction consists in disabling a function that is affecting the proper operation of the application of which that program forms a part (CJEU, C-13/20, para. 42, 53). While this is a significant clarification, especially for software maintenance and reliability, the Court simultaneously introduced important constraints that limit the potential application of this right to security research. Specifically, the judgement underlines that decompilation is lawful only ‘to the extent necessary’ to effect the correction, and ‘in compliance, where appropriate, with the conditions laid down in the contract’ with the copyright holder (CJEU, C-13/20, para. 75 point 2).

This conditionality creates two legal obstacles for security researchers. First, the necessity threshold is restrictive: only code-level interventions directly aimed at correcting a functional error are permitted. Broader research purposes would not typically meet this standard. Second, the reference to license terms opens the door for software vendors to contractually narrow or exclude decompilation rights altogether. This means that researchers may be legally constrained from investigating software beyond narrowly defined corrective purposes, even where they act in good faith and hold a legitimate copy. Consequently, while *Top System*

offers a modest background for error-correction decompilation, it reinforces the need for an explicit and harmonized legal exemption for good-faith security research within EU copyright law.

Slovak and Czech law deal with hunting vulnerabilities only partially. Act Number 185/2015 Coll. Copyright Act as amended and Czech Act No 121/2000 Coll. as amended, provide limited protections for security researchers, particularly when vulnerabilities are discovered through reverse engineering. Research-related exemptions apply to making copies of source code for interoperability purposes and observing, studying, or testing software functionality to determine its principles. However, these exemptions are restricted, as security researchers can only use the obtained information for interoperability purposes, not for security analysis. Consequently, if vulnerability disclosure involves copying, modifying, or decompiling software beyond interoperability needs, researchers may infringe copyright law.

Additionally, circumventing TPMs to conduct security testing is generally prohibited. Although the Slovak and Czech Copyright acts provide an exemption for research-related uses of copyrighted works (use of the work for research purposes under Section 44 of the Slovak Copyright Act and Section 31(1) (c) of the Czech Copyright Act), both laws do not explicitly cover cybersecurity research, leaving researchers in legal uncertainty.

In Germany, there is also a risk of prosecution when analysing software code if it is protected by copyright. The reproduction of the work may be permitted, however the security researcher would first have to be authorised to use a copy of the programme. Secondly, the reproduction would have to be necessary to correct an error in the computer programme. It is not clear whether these conditions are met in the case of error detection by security researchers [47].

In France, the legal framework governing security research benefits from a significant exception under Article L122-6-1 III of the French Intellectual Property Code, which provides a clear exemption for individuals who have the right to use software. This provision allows users to observe, study, or test the functioning or security of software without requiring the author’s authorization, provided that such activities are conducted as part of the loading, display, execution, transmission, or storage of the software that they are entitled to use. This exception is particularly relevant to security researchers, as it creates a legal basis for reverse engineering, security testing, and vulnerability research, shielding these activities from copyright infringement claims.

Legal protection of copyright must be proportionate and not prohibit those devices or activities that have a significant purpose or use, other than infringing technical protection. In particular, such protection must not impede research in the field of cryptography, as is also apparent from EU law (Directive 2009/24/EC of the European Parliament and of the Council of 23 April 2009 on the legal protection of computer programs, recital 48). Although cybersecurity research includes other areas than cryptography, there is a clear purpose not to impede development and research [72].

A broader EU-level reform of copyright law is needed to explicitly recognize security research as a legitimate activity, particularly by expanding copyright exemptions to include cybersecurity research, permitting reverse engineering for security testing beyond interoperability purposes, and allowing circumvention of TPMs for security research, provided that findings are disclosed responsibly.

Safe harbours in EU cybersecurity law

The NIS2

The NIS2 in Article 12 mandates Member States to establish national policies on vulnerability disclosure and designate a national CSIRT as a coordinator, ensuring structured cooperation between security researchers and affected organizations. Recital 60 explicitly acknowledges the challenges faced by security researchers, including potential criminal liability in certain jurisdictions. To counter this, Member States are encouraged to adopt nonprosecution guidelines and exemptions from civil liability for ethical security research. Moreover, Recital 61 defines the role of CSIRTs in the vulnerability disclosure process, assigning them the responsibility of facilitating interactions between reporting entities and affected manufacturers or ICT service providers.

The NIS2 implementing act have reinforced the importance of CVD as part of cybersecurity risk management. Under the Commission Implementing Regulation (EU) 2024/2690, relevant digital service providers including cloud computing, data centre, and managed security service providers, must establish internal procedures for vulnerability handling and explicitly disclose vulnerabilities in accordance with their national CVD policies. The Regulation 2024/2690 operationalizes Article 21 of the NIS2 and represents the first mandatory and harmonized EU-level obligation to implement CVD procedures, even if limited to certain categories of digital infrastructure providers. This obligation targets not only timely mitigation but also proactive obligations to, i.e.

- (a) monitor information about vulnerabilities through appropriate channels, such as announcements of CSIRTs, competent authorities, or information provided by suppliers or service providers;
- (b) perform, where appropriate, vulnerability scans and record evidence of the results of the scans, at planned intervals;
- (c) address, without undue delay, vulnerabilities identified by the relevant entities as critical to their operations;
- (d) ensure that their vulnerability handling is compatible with their change management, security patch management, risk management, and incident management procedures;
- (e) lay down a procedure for disclosing vulnerabilities in accordance with the applicable national CVD policy (point 6.10.2 of the Regulation 2024/2690).

Complementing this regulatory requirement, ENISA's Technical Implementation Guidance [73] elaborates that vulnerabilities classified as 'high' or 'critical' according to the Common Vulnerability Scoring System or national CSIRT definitions, must be addressed without undue delay. Furthermore, entities are expected to communicate vulnerabilities internally and externally, share findings from technical scans with relevant authorities, and disclose previously unknown vulnerabilities to designated CSIRTs. This structured approach to CVD also includes identifying a single point of contact for security communication with suppliers and partners.

Building on our earlier findings that Member States have experimented with various approaches to CVD and researcher protection, it becomes evident that the EU has chosen to establish a predominantly top-down framework. Such an approach has the po-

tential to provide greater legal certainty and uniformity across the Union. However, its effectiveness ultimately depends on how it is transposed into national both civil and criminal law and on the expertise and institutional capacity of national authorities.

The CSA

The CSA (Article 55/1, c–d) complements the NIS2 by further strengthening the CVD framework, requiring manufacturers and ICT service providers whose products have been certified under the EU cybersecurity certification framework to disclose their contact information publicly and accepted reporting methods for vulnerability disclosure. The regulation of CVD in the CSA can help bridge the gap between cybersecurity certification and the software industry. [74]

CVD policies could play an important role in the efforts of Member States to enhance cybersecurity (CSA, recital 30). In line with this, the CSA (Article 6/1, b) provides that ENISA shall assist Member States and the Union's institutions, bodies, offices, and agencies in the establishment and implementation of vulnerability disclosure policies on a voluntary basis.

The CSA (Article 54/1, m) also introduces the European Cybersecurity Certification Framework. This framework must also include rules for the reporting and handling of previously unknown vulnerabilities in ICT products, ICT services, and ICT processes from a cybersecurity perspective.

The Cyber Resilience Act

The Cyber Resilience Act (CRA) introduces further measures to enhance CVD and promote legal certainty for security researchers engaging in vulnerability reporting. Recitals 75 and 76 emphasize the need to address legal uncertainties for researchers, explicitly encouraging Member States to introduce guidelines preventing criminal prosecution and civil liability for individuals and organizations engaged in responsible vulnerability research.

The CRA goes further in regulation of the CVD process. It not only requires manufacturers of products with digital elements to establish and maintain CVD policies and procedures to process and remediate vulnerabilities reported from both internal and external sources [CRA, article 13(8), subpoint 6 and Annex I, Part II(5), requires manufacturers to have appropriate procedures, including CVD policies, for handling vulnerability reports from internal or external sources]. In addition, the CRA supports a culture of transparency and collaboration by allowing voluntary reporting of vulnerabilities, cyber threats, and near misses to CSIRTs or ENISA by manufacturers or third parties, including security researchers [CRA, Article 15(1) (2), allows voluntary reporting of vulnerabilities, cyber threats, and incidents to CSIRTs designated as coordinators or to ENISA by manufacturers and any natural or legal person], and mandates that manufacturers provide a public single point of contact for receiving such reports, along with access to their CVD policy (CRA, Annex II, point 2, requires manufacturers to provide a single point of contact for vulnerability reporting and access to their CVD policy). While the CRA does not mandate bug bounty programs, the CRA explicitly encourages manufacturers to consider them. The CRA states manufacturers should ensure coordinated disclosure programs incentivize reporting of vulnerabilities by ensuring that individuals receive recognition and compensation for their efforts (bug bounty programs) (CRA, recital 76).

Furthermore, the CRA provides flexibility in managing disclosure timelines, allowing manufacturers and CSIRTs to delay public dissemination of vulnerabilities under exceptional circumstances, particularly when active exploits are detected in the wild. This ensures that security risks are mitigated before vulnerabilities become widely known and weaponized by malicious actors (CRA, Article 16).

Following the release of the CRA's standardisation request on 3 February 2025, the European Commission outlined an ambitious roadmap to produce 41 deliverables in the coming years, aiming to harmonize security expectations and procedural frameworks in multiple legislative instruments [Commission implementing decision of 3.2.2025 on a standardisation request to the European Committee for Standardisation (CEN), the European Committee for Electrotechnical Standardisation (Cenelec), and the European Telecommunications Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)]. This roadmap explicitly anticipates overlaps between the CRA and other major regulatory initiatives, such as the AIA, the European Health Data Space Regulation, the Machinery Regulation [Regulation (EU) 2023/1230 of the European Parliament and of the Council of 14 June 2023 on machinery and repealing Directive 2006/42/EC of the European Parliament and of the Council and Council Directive 73/361/EEC], and the Chips Act [Regulation (EU) 2023/1781 of the European Parliament and of the Council of 13 September 2023 establishing a framework of measures for strengthening Europe's semiconductor ecosystem and amending Regulation (EU) 2021/694], underscoring that core cybersecurity requirements (including CVD) must be integrated coherently, even when these products are concurrently subject to other specialized rules.

The CRA standardization request mandates that European Standardisation Organisations develop horizontal standards on vulnerability handling processes by 30 August 2026 (see Annex I of the Commission implementing decision, n166). These standards are envisioned to cover manufacturers' policies for managing vulnerabilities, including the integration of a CVD policy.

Lack of technical safe harbours

The NIS2, the CSA, nor the CRA does not provide harmonization for the protection of security research, nor does EU legislation define what constitutes security research or who qualifies as a security researcher. Additionally, it does not guarantee nor recognize need for technical safe harbours.

The concept of technical safe harbours gets nowadays more attention in the context of AI security research [75]. It is necessary that companies should not only provide legal protections but also technical safe harbours to prevent security researchers from facing account suspensions or automated moderation while engaging in vulnerability disclosure. While focused on AI security, the question arises as to whether technical safe harbours should extend to cybersecurity research beyond AI vulnerabilities.

Without technical safe harbours, security researchers risk losing access to platforms, cloud services, or even core investigative

tools like GitHub, AWS, or security forums. Implementing technical safe harbours would provide:

- Protection against automated bans—ensuring researchers do not face account suspensions or restrictions when conducting ethical security testing.
- Exemptions from restrictive Terms of Service violations—explicitly allowing responsible vulnerability research to proceed without risk of punitive actions.
- Reinstatement mechanisms—providing a structured appeal process for researchers mistakenly flagged by security systems.

Inspiration for what such technical safe harbours might look like can be found again in Bug Bounty programs, contractual terms and conditions, or principles of responsible CVD. A fascinating work in this regard is the article by Walshe and Simpson [33]. These authors focused on the information provided to researchers and analysed the formal (legal) and informal (technical) restrictions on the performance of research activities [33]. At the same time, they published a dataset that includes 543 policies of Bug bounty programs and principles of CVD [4]. As part of our research, we analysed the policies in question and presented several conclusions below.

In addition to the standard legal protection of security researchers from legal sanctions for ethical testing of systems and revealing vulnerabilities, these policies or principles can also include rules that ensure that testing and searching for security vulnerabilities occurs without disrupting real services or damaging data. This is mainly reflected in several rules:

- Rules regarding the maintenance of the proper operation of the tested system—the researcher must not interrupt or disrupt the proper operation of the tested system. During the analysis, we found several examples of rules: 'You must not disrupt, compromise, destroy data, or interrupt or degrade our services.', 'You may not destroy or degrade the performance of our products and services, ...', and '... Finally, you agree to not interrupt or degrade the Organisation service'.
- Rules regarding the maintenance of data integrity and availability—the researcher must not damage, alter or destroy data contained in the test systems, including the related infrastructure. This is a relatively complex rule. The researcher must anticipate the outcome of his actions. During the analysis, we found several examples of rules: 'You further agree not to change, damage or destroy any data stored on the Organisation servers with the exception of an account created for testing purposes. ...', '... or violate the privacy and integrity of user accounts and data.', and 'Please be respectful and don't... destroy any data'.
- Rules regarding data confidentiality—the researcher must not violate the confidentiality of the obtained data, including violating the protection of personal and other sensitive data. In other words, publishing even a part of this data is impossible as part of the disclosure process. During the analysis, we found several examples of rules: 'Organisation has never given permission/authorisation (either implied or explicit) to an individual or group of individuals to extract personal information or content of Organisation users and publicise this information on the open, public-facing Internet without user con-

sent'. Another example: 'Please be respectful and don't violate anyone's privacy, interfere with anyone's account, ...'

These basic rules limit researchers in how they do their research. They must predict the consequences of doing individual activities, especially the disruption of the system and data alteration. Should they avoid tools and procedures that might cause these consequences? This would mean only doing noninvasive vulnerability testing, which would limit the investigation.

Conclusions

The NIS2, the CSA, and the CRA together create a comprehensive and legally binding framework for CVD across the EU. These regulations mandate structured CVD policies, provide legal protections for security researchers, and establish centralized vulnerability tracking. Their goal is to enhance cybersecurity and resolve longstanding legal uncertainties faced by researchers. The development of decentralised or centralised approaches has both pros and cons. However, given the fragmented national approaches and increasing cross-border cybersecurity threats, a top-down EU model for CVD offers greater consistency and legal certainty. It enables more effective coordination across Member States and sectors.

While these developments are promising, implementation at the national level remains crucial. Member States must ensure that national laws and enforcement practices align with the outlined principles, particularly concerning the nonprosecution of security researchers and the establishment of structured disclosure mechanisms.

The NIS2 and the CRA namely in their recitals send signals to member states to create safe harbours for reporters and especially for security researchers. It is essential to clarify that recitals, while useful in understanding the purpose and objectives of legislation, do not in themselves carry binding legal force. This legal gap reinforces the argument that the EU should adopt explicit and binding provisions to ensure legal certainty and protection for security researchers across member states. We believe that there is strong demand for EU-harmonized protection for security research in finding and disclosing vulnerabilities that besides anything else will bring positive incentives for academic and commercial security research in the EU. Ultimately, the success of the EU's CVD framework will depend on collaboration between regulators, manufacturers, researchers, and CSIRTs.

We can agree that the best approach to operating a vulnerability disclosure program is one based on autonomy. An autonomously operated vulnerability disclosure program indicates a high level of security awareness and a proactive commitment from organizations to address the issue of security vulnerabilities. However, it is difficult to expect such level of autonomy in the current situation.

Further, transparency and accountability must be core principles in CVD frameworks. Organizations that receive vulnerability reports should be required to acknowledge disclosures, track remediation progress, and publish anonymized reports on vulnerability management outcomes. This level of transparency fosters trust between researchers and industry stakeholders, reinforcing the value of security research.

Human rights principles must guide security research. Individuals should be free to conduct and share scientific research for societal benefit. This freedom of communication also applies to

security research findings. Researchers must be allowed to share their discoveries with the public to inform them of potential cyber-crime vulnerabilities. The CVD process aligns with these principles by enabling researchers to contribute to scientific progress while ensuring that vulnerabilities are disclosed responsibly.

We strongly advocate to the EU and each Member State to protect beneficial security research in the EU law or national laws, supported by policies and guidelines that companies and law enforcement can follow. There a coherent European framework for protecting good-faith security research should rest on two inter-linked pillars: (i) mandatory CVD policies and (ii) substantive legal exemptions from liability. The recent Regulation 2024/2690 represents a key first step by requiring digital infrastructure entities, to establish internal procedures for handling and disclosing vulnerabilities in accordance with national CVD policies. However, while this creates a procedural obligation for entities to receive disclosures, it does not yet establish legal certainty for the researchers making them.

To close this gap, EU lawmakers should include legal exemptions in cybersecurity legislation. This would protect researchers acting in good faith who follow reporting channels and do only what is necessary to identify a vulnerability. This would complement the CVD obligation, guaranteeing researchers are both able and permitted to report vulnerabilities. Including this in horizontal cybersecurity law would create a legal and technical safe harbour. Researchers would have access to disclosure policies without risk of criminal or civil liability.

Acknowledgements

Authors acknowledge the assistance of Hovsep Kocharyan and Lusine Vardanyan (early career researchers, Palacký University Olomouc) for their help with final editing of the paper.

Author contributions

Michal Rampášek (Conceptualization [equal], Data curation [equal], Formal Analysis [equal], Investigation [equal], Methodology [equal], Resources [equal], Validation [equal], Visualization [equal], Writing – original draft [equal], Writing – review & editing [equal]), Jozef Andraško (Conceptualization [equal], Data curation [equal], Formal Analysis [equal], Funding acquisition [equal], Investigation [equal], Methodology [equal], Visualization [equal], Writing – original draft [equal], Writing – review & editing [equal]), Pavol Sokol (Conceptualization [equal], Data curation [equal], Investigation [equal], Methodology [equal], Visualization [equal], Writing – original draft [equal], Writing – review & editing [equal]), Ondrej Hamulak (Funding acquisition [lead], Methodology [equal], Project administration [equal], Supervision [lead], Validation [equal], Writing – review & editing [equal])

Conflicts of interest

None declared.

Funding

The work on this paper was supported by the Slovak Research Development Agency under the contract number APVV-23-0137—legal and technical aspects of cybersecurity situational awareness (grant number: 101127038) and Project TECHSCALE (number CZ.02.01.01/00/22_008/0004587), financed by the Ministry of Education, Youth and Sports, OP JAC excellent research programme, supported by ERDF/ESF.

References

1. Alexopoulos N, Meneely A, Arnouts D *et al*. Who are vulnerability reporters? A large-scale empirical study on FLOSS. In: *Proceedings of the 15th ACM/IEEE International Symposium on Empirical Software Engineering and Measurement (ESEM)*. New York: Association for Computing Machinery, 2021, 25. <https://doi.org/10.1145/3475716.3475783>
2. Van Daalen O. In defense of offense: information security research under the right to science. *Comput Law Secur Rev* 2022;**46**:105706. <https://doi.org/10.1016/j.clsr.2022.105706>
3. Xiaozhou L, Moreschini S, Zhang Z *et al*. The anatomy of a vulnerability database: a systematic mapping study. *J Syst Softw* 2023;**201**:111–679. <https://doi.org/10.1016/j.jss.2023.111679>
4. Repository documents for Walshe T, Simpson A. Towards a greater understanding of coordinated vulnerability disclosure policy documents. *Digit Threats Res Pract* 2023;**4**:1–36. <https://doi.org/10.1145/35861>. Available at GitHub repository. <https://github.com/walshe96/cvd-policy-documents> (21 January 2025, date last accessed).
5. Zrahia A. Navigating vulnerability markets and bug bounty programs: a public policy perspective. *Internet Policy Rev* 2024;**13**:1–30. <https://doi.org/10.14763/2024.1.1740>
6. Arora A, Nandkumar A, Telang R. Does information security attack frequency increase with vulnerability disclosure? An empirical analysis. *Inf Syst Front* 2006;**8**:350–62. <https://doi.org/10.1007/s10796-006-9012-5>
7. Sen R, Choobineh J, Kumar S. Determinants of software vulnerability disclosure timing. *Prod Oper Manag* 2020;**29**:2532–52. <https://doi.org/10.1111/poms.13120>
8. Lisi A, Mukherjee P, De Santis L *et al*. Automated responsible disclosure of security vulnerabilities. *IEEE Access* 2022;**10**:10472–89. <https://doi.org/10.1109/ACCESS.2021.3126401>
9. Pil YS. The way forward for security vulnerability disclosure policy: comparative analysis of US, EU, and Netherlands. In: R Lee (ed.) *Big Data, Cloud Computing, and Data Science Engineering*. BCD 2022. Studies in Computational Intelligence, Vol. **1075**. Cham: Springer, 2023, 119–31. https://doi.org/10.1007/978-3-031-19608-9_10
10. Dickmann R. Vulnerability management as compliance requirement in product security regulation—a game changer for producers' liability and consequential improvement of the level of security in the Internet of Things? *Int Cybersec Law Rev* 2023;**4**:21–37. <https://doi.org/10.1365/s43439-022-00064-9>
11. Ruohonen J, Timmers P. Vulnerability Coordination under the Cyber Resilience Act. 2025. <https://arxiv.org/html/2412.06261v1> (17 January 2025, date last accessed).
12. Sardaryzadeh A. Security researchers battle against the DMCA. *Chi Kent J Intell Prop* 2023;**22**:38–183. <https://scholarship.kentlaw.iit.edu/ckjip/vol22/iss2/10> (17 January 2025, last accessed).
13. Brodowski D. (Ir-)responsible disclosure of software vulnerabilities and the risk of criminal liability. *IT—Inf Technol* 2015;**57**:357–65. <https://doi.org/10.1515/itit-2015-0014>
14. Vostoupal J, Stupka V, Harašta J *et al*. The legal aspects of cybersecurity vulnerability disclosure: to the NIS 2 and beyond. *Comput Law Secur Rev* 2023;**53**:105988. <https://doi.org/10.1016/j.clsr.2024.105988>
15. OECD. *Frascati Manual 2015. Guidelines for Collecting and Reporting Data on Research and Experimental Development*. Paris, 2015. <https://www.oecd.org/sti/inno/frascati-manual.htm> (17 January 2025, date last accessed).
16. Github. Bounty-targets-data. 2025. <https://github.com/arkadiyt/bounty-targets-data/blob/main/data/domains.txt> (17 January 2025, date last accessed).
17. Hall JL, Dean BC. The importance of security research. Washington: Center for Democracy and Technology, 2025. <https://cdt.org/insights/the-importance-of-security-research-four-case-studies/> (17 January 2025, date last accessed).
18. Edgar TW, Manz DO. *Research Methods for Cyber Security*. Cambridge: Syngress, 2017.
19. VOSviewer tool. <https://www.vosviewer.com/> (17 January 2025, date last accessed).
20. Cattell S, Ghosh A, Kaffee LA. Coordinated flaw disclosure for AI: beyond security vulnerabilities. 2025. <https://arxiv.org/html/2402.07039v2> (16 August 2025, date last accessed).
21. Park S, Albert K. A researcher's guide to some legal risks of security research. Cambridge: Harvard Cyberlaw Clinic, 2025. <https://clinic.cyber.harvard.edu/wp-content/uploads/2024/08/Security-Researchers-Guide-8-2-24.pdf> (16 August 2025, date last accessed).
22. Katsikeas S, Johnson P, Ekstedt M, Lagerström R. Research communities in cyber security: a comprehensive literature review. *Comput Sci Rev* 2021;**42**:100431. <https://doi.org/10.1016/j.cosrev.2021.100431>
23. OECD. Encouraging vulnerability treatment—overview for policy makers. Paris, 2025. <https://www.oecd.org/sti/encouraging-vulnerability-treatment-0e2615ba-en.htm> (16 August 2025, date last accessed).
24. ENISA. Coordinated vulnerability disclosure policies in the EU. Heraklion, 2025. <https://www.enisa.europa.eu/sites/default/files/publications/Coordinated%20Vulnerability%20Disclosure%20policies%20in%20the%20EU.pdf> (16 August 2025, last accessed).
25. Weulen Kranenbarg M, Holt TJ, Van der Ham J. Don't shoot the messenger! A criminological and computer science perspective on coordinated vulnerability disclosure. *Crime Sci* 2018;**7**:16. <https://doi.org/10.1186/s40163-018-0090-8>
26. Freiling F. Zum umgang mit erkenntnissen der IT-sicherheitsforschung. In: S Golla, D Brodowski (eds). *IT-Sicherheitsforschung und IT-Strafrecht*. Tübingen: Mohr Siebeck, 2023, 21–33. <https://doi.org/10.1628/978-3-16-162184-0>
27. Van't Hof C. *Helpful Hackers: How the Dutch Do Responsible Disclosure*. Amsterdam: Tek Tok Uitgeverij (Vior Webmedia), 2016.

28. Pupillo L, Ferreira A, Varisco G. Software vulnerability disclosure in Europe: technology, policies and legal challenges: report of a CEPS Task Force. Brussels: Centre for European Policy Studies, 2025. https://www.ceps.eu/wp-content/uploads/2018/06/CEPS%20TFRonsVD%20with%20cover_0.pdf (17 January 2025, date last accessed).
29. Cluley G. Silenced for two years by Volkswagen, car hackers reveal their paper into security hole. Bucharest: Bitdefender, 20215. <https://www.bitdefender.com/en-us/blog/hotforsec/silenced-for-two-years-by-volkswagen-car-hackers-reveal-their-paper-into-security-hole> (16 August 2025, date last accessed).
30. The Times of Malta. Drop the charges against students, lecturer and reform law. 2025. <https://timesofmalta.com/article/drop-charges-students-lecturer-reform-law-momentum.1106107> (16 August 2025, date last accessed).
31. The Malta Independent. Updated: students, lecturer accused of ethical hacking granted presidential pardon. 2025. <https://www.independent.com.mt/articles/2025-07-01/local-news/Students-lecturer-accused-of-ethical-hacking-granted-presidential-pardon-6736271319> (16 August 2025, date last accessed).
32. Scherschel FA. Modern solution: court of appeal confirms guilt of security researcher. Niedersachsen: Heise medien, 2024. <https://www.heise.de/en/news/Modern-Solution-Court-of-Appeal-confirms-guilt-of-security-researcher-10007206.html> (16 August 2025, date last accessed).
33. Walshe T, Simpson A. Towards a greater understanding of coordinated vulnerability disclosure policy documents. *Digit Threats Res Pract* 2023;**4**:1–36. <https://doi.org/10.1145/3586180>
34. Walshe T, Simpson AC. Coordinated vulnerability disclosure programme effectiveness: issues and recommendations. *Comput Secur* 2022;**123**:102936 <https://doi.org/10.1016/j.cose.2022.102936>
35. Macnish K, Van der Ham J. Ethics in cybersecurity research and practice. *Technol Soc* 2020;**63**:101382. <https://doi.org/10.1016/j.techsoc.2020.101382>
36. Loi M, Christen M. Ethical frameworks for cybersecurity. In: M Christen, B Gordijn, M. Loi (eds) *The Ethics of Cybersecurity. The International Library of Ethics, Law and Technology*. Vol. 21. Cham: Springer, 2020, 73–95. https://doi.org/10.1007/978-3-030-29053-5_4
37. European Court of Human Rights. Women on Waves and Others v Portugal. Application no. 31276/05. Strasbourg, 2009. <https://hudoc.echr.coe.int/eng/?i=001-91113> (18 January 2025, date last accessed).
38. Bychawska-Siniarska D. *Protecting the Right to Freedom of Expression under the European Convention on Human Rights—A Handbook for Legal Practitioners*. Strasbourg: Council of Europe, 2025. <https://coillink.org/20.500.12592/bk5xtw> (17 January 2025, date last accessed).
39. Pfefferkorn R. The importance of protecting good-faith security research. Stanford Law School Cyberlaw Blog, 2025. <http://cyberlaw.stanford.edu/blog/2020/09/importance-protecting-good-faith-security-research> (17 January 2025, date last accessed).
40. Tesla. Product security. Austin, 2025. https://www.tesla.com/en_eu/legal/security (17 January 2025, date last accessed).
41. Del-Real C, Rodriguez Mesa MJ. From black to white: the regulation of ethical hacking in Spain. *Inf Commun Technol Law* 2022;**32**:207–39. <https://doi.org/10.1080/13600834.2022.2132595>
42. European Commission-Directorate-General for Migration and Home Affairs. Brussels, 2025. https://home-affairs.ec.europa.eu/news/commission-proposes-sign-and-conclude-un-convention-against-cybercrime-2025-07-16_en (16 August 2025, date last accessed).
43. Cohen I. The UN cybercrime convention threatens security research. The US should do something about it. CyberScoop, 2025. <https://cyberscoop.com/un-cybercrime-treaty-threatens-security-research-ilona-cohen-op-ed/> (17 January 2025, date last accessed).
44. Tropina T. This is not a human rights convention!': the perils of overlooking human rights in the UN cybercrime treaty. *J Cyber Policy* 2024;**9**:200–20. <https://doi.org/10.1080/23738871.2024.2419517>
45. United Nations. Oral Statement, United Nations Ad Hoc Committee to Elaborate a Comprehensive International Convention on Countering the Use of ICTs for Criminal Purposes Intervention on Groups 9, 10: Specifically Proposed Articles 6-10, 36 of the Draft Treaty, 25 August 2023. New York, 2025. https://www.unodc.org/documents/Cybercrime/AdHocCommittee/6th_Session/Submissions/Multi-stakeholders/Accss_Now_2.pdf (16 August 2025, date last accessed).
46. United Nations. Article 19 and Human Rights Watch's Comments on the Draft Text of the UN Cybercrime Convention. New York, 2025. https://www.unodc.org/documents/Cybercrime/AdHocCommittee/6th_Session/Submissions/Multi-stakeholders/Human_Rights_Watch.pdf (16 August 2025, date last accessed).
47. Schröder JC. Ein rechtspolitischer Vorschlag, um die Risiken einer strafverfolgung von IT-sicherheitsforschern zu reduzieren. *Onlinezeitschrift für Höchststrichterliche Rechtsprechung zum Strafrecht* 2024; **25**:75–87. <https://www.hrr-strafrecht.de/hrr/archiv/24-03/index.php?sz=6> (16 August 2025, date last accessed).
48. Fiorinelli GA, Zucca MA. Is the road to hell paved with good intentions? A criminological and criminal law analysis of prospective regulation for ethical hacking in Italy and the EU, ITASEC. In: *Proceedings of the TASEC 2024: The Italian Conference on Cybersecurity*. CEUR-WS.org, 2024. <https://ceur-ws.org/Vol-3731/paper45.pdf> (16 August 2025, date last accessed).
49. National Cyber Security Centre. *Coordinated Vulnerability Disclosure: The Guideline*. Netherlands: Ministry of Justice and Security, 2018. <https://english.ncsc.nl/publications/publications/2019/juni/01/coordinated-vulnerability-disclosure-the-guideline> (17 January 2025, date last accessed).
50. Beky A. Hacker éthique: la législation française enfin claire?, Silicon.fr, 2016. <https://www.silicon.fr/hacker-ethique-legislation-francaise-claire-160842.html> (17 January 2025, date last accessed).
51. Slovak National Security Authority. Návod na oznamovanie zraniteľností [Vulnerability reporting instructions]. 2019. <https://www.sk-cert.sk/sk/oznamovanie-zranitelnosti/index.html> (20 January 2025, date last accessed).
52. Project Achilles 2025. <https://www.csirt.gov.sk/wp-content/uploads/2024/03/Achilles.pdf> (20 January 2025, date last accessed).

53. NÚKIB. Coordinated vulnerability disclosure in the Czech Republic. 2025. https://www.enisa.europa.eu/sites/default/files/ncss-map/strategies/national-implementation/CZ_CVD_POLICY.pdf (16 August 2025, date last accessed).
54. MaltcaCIPD. National Coordinated Vulnerability Disclosure Policy (NCVDP). 2024. <https://mdia.gov.mt/app/uploads/2024/12/P-SPG-001-National-Coordinated-Vulnerability-Disclosure-Policy.pdf> (16 August 2025, date last accessed).
55. ACN. Cybersecurity research & innovation agenda 2023–2026. version 1.0 2023. 2025. https://www.acn.gov.it/portale/documents/20119/87266/ACN_ResearchInnovationAgenda_EN.pdf/e8b2b315-b3db-fab4-be32-293422266986?t=1704453743342 (16 August 2025, date last accessed).
56. NCSC. Vulnerability Disclosure Toolkit. 2020. <https://www.ncsc.gov.uk/information/vulnerability-disclosure-toolkit#why-encourage-vulnerability-disclosure> (16 August 2025, date last accessed).
57. Cyber UP. Briefing on the Crime and Policing Bill: a critical opportunity to improve national resilience against cyberattacks and grow the domestic cyber security sector. 2025. <https://bills.parliament.uk/publications/60406/documents/6385> (16 August 2025, date last accessed).
58. Home Office. Guidance Report a vulnerability on a Home Office system. 2025. <https://www.gov.uk/guidance/report-a-vulnerability-on-a-home-office-system> (16 August 2025, date last accessed).
59. CERT.PL NASK. Coordinated vulnerability disclosure (CVD) policy. 2025. <https://cert.pl/en/cvd/> (16 August 2025, date last accessed).
60. Kulesza J. *Kodeks Karny Komentarz*. [Penal Code Commentary]. Warsaw: Wolters Kluwer, 2025.
61. In: Konarska-Wrzošek V. (ed.), *Kodeks Karny Komentarz*. [Penal Code Commentary]. Warsaw: Wolters Kluwer, 2023.
62. CCB. Coordinated Vulnerability Disclosure Policy (CVD) and Vulnerability Detection Reward Program. 2025. <https://ccb.belgium.be/regulation/cvdp> (16 August 2025, date last accessed).
63. BSI. BSI CVD guideline for security researchers. 2025. https://www.bsi.bund.de/EN/IT-Sicherheitsvorfall/IT-Schwachstellen/it-schwachstellen_node.html (16 August 2025, date last accessed).
64. BSI. Die Lage der IT-Sicherheit in Deutschland 2024. 2025, 32. https://www.bsi.bund.de/SharedDocs/Downloads/DE/BSI/Publikationen/Lageberichte/Lagebericht2024.pdf?__blob=publicationFile&v=5 (16 August 2025, date last accessed).
65. Bundesministerium der Justiz und für Verbraucherschutz. Gesetz zur Änderung des Strafgesetzbuches—Modernisierung des Computerstrafrechts 4 November 2024. 2025. https://www.bmjv.de/SharedDocs/Gesetzgebungsverfahren/DE/2024_ComputerStrafR.html (16 August 2025, date last accessed).
66. Deloitte. Coalition agreement between the CDU, CSU, and SPD 21st legislative period. 2025, 90. https://www.koalitionsvertrag2025.de/sites/www.koalitionsvertrag2025.de/files/koav_2025.pdf (15 October 2025, date last accessed).
67. Bundesrechtsanwaltskammer. Modernisierung des Computerstrafrechts: BRAK begrüßt Reformüberlegungen des Bundesjustizministeriums 19 March 2025. 2025. <https://www.brak.de/newsroom/newsletter/nachrichte-n-aus-berlin/2025/ausgabe-6-2025-v-1932025/modernisierung-des-computerstrafrechts-brak-begruessst-reformueberlegungen-des-bundesjustizministeriums/> (16 August 2025, date last accessed).
68. Federal Register. Exemption to Prohibition on Circumvention of Copyright Protection Systems for Access Control Technologies. 2025. <https://www.federalregister.gov/documents/2024/10/28/2024-24563/exemption-to-prohibition-on-circumvention-of-copyright-protection-systems-for-access-control> (16 August 2025, date last accessed).
69. Van Buren v. United States, 593 U.S.. 2021. <https://supreme.justia.com/cases/federal/us/593/19-783/> (16 August 2025, date last accessed).
70. U.S. Department of Justice. Department of Justice Announces New Policy for Charging Cases under the Computer Fraud and Abuse Act (Press release). 2025. <https://www.justice.gov/archives/opa/pr/departments-justice-announces-new-policy-charging-cases-under-computer-fraud-and-abuse-act> (16 August 2025, date last accessed).
71. Xiao M, Sellars A, Scheffler S. When anti-fraud laws become a barrier to computer science research. In: *Proceedings of the 2025 Symposium on Computer Science and Law*. New York: ACM, 2025, 1–16. <https://doi.org/10.48550/arXiv.2502.02767>
72. Adamová Z, Hazucha B. § 60 “Obchádzanie technologického ochranného opatrenia” [§ 60 “Circumvention of a technological protection measure”]. In: Z. Adamová al. et (eds). *Autorské Právo a Práva Súvisiace s Autorským Právom*. [Copyright law and related rights]. Prague: C.H. Beck, 2018.
73. ENISA. Echnical Implementation Guidance. Version 1.0. 2025, 103. https://www.enisa.europa.eu/sites/default/files/2025-06/ENISA_Technical_implementation_guidance_on_cyber_security_risk_management_measures_version_1.0.pdf (16 August 2025, date last accessed).
74. Hernandez-Ramos JL, Matheu SN, Skarmeta A. The challenges of software cybersecurity certification [Building Security In]. *IEEE Secur Priv* 2021;19:9–102. <https://doi.org/10.1109/MSEC.2020.3037845>
75. Longpre S, Kapoor S, Klyman K et al. A safe harbor for AI evaluation and red teaming. In: *Proceedings of the 41st International Conference on Machine Learning*. New York: ACM, 2024. <https://arxiv.org/abs/2403.04893> (20 January 2025, date last accessed).